

[AI-03] Công Bố Sử Dụng AI

Tuyên bố chung

Nhóm 06 - KDBK sử dụng AI trong seminar **T09 - Security Testing (DAST / SAST)** với vai trò hỗ trợ học tập, soạn thảo, rà soát kỹ thuật, phân tích kết quả scan và chuẩn hóa tài liệu. AI không được xem là nguồn kết luận cuối cùng. Mọi nội dung đưa vào sản phẩm nộp bài đều đã được thành viên phụ trách đọc lại, chỉnh sửa, đối chiếu với source code, output công cụ, tài liệu chính thức hoặc bằng chứng trong repository.

Nhóm không nộp nguyên văn output AI khi chưa kiểm chứng. Các phần liên quan đến lỗ hổng bảo mật, PoC, remediation, ZAP/Semgrep report và AI triage đều cần được human validation trước khi dùng làm bằng chứng chính thức.

Thành viên 1 - Lê Trung Kiên

- MSSV: 23127075
- Nhóm: Group 06 - KDBK
- Đề tài: T09 - Security Testing (DAST / SAST)

Tóm tắt sử dụng AI

Công cụ	Mục đích	Đầu vào đã cung cấp	Nội dung đã sử dụng	Cách tự kiểm chứng
Gemini 3.1 Pro, NotebookLM	Tìm nguồn và tìm hiểu DAST, OWASP ZAP, OWASP Top 10.	Yêu cầu tìm nguồn chính thống và giải thích khái niệm DAST, ZAP, OWASP Top 10 cho seminar Security Testing.	Nội dung nền tảng về DAST, vai trò của ZAP, cách dùng OWASP Top 10 để phân loại rủi ro và nguồn tham khảo cho tài liệu.	Đối chiếu lại output AI với nguồn chính thống của OWASP và ZAP trước khi đưa vào user guide/slide.
GPT-5.5	Hỗ trợ viết script cấu hình output format của ZAP scan.	Yêu cầu xuất ZAP scan ra json và html , hỗ trợ pipeline đọc kết quả và báo cáo thủ công.	Draft logic chọn report format, cấu hình output path và phần metadata/tag cho kết quả scan.	Đọc lại script/output, kiểm tra format JSON/HTML, bổ sung phần tag để trace với nhóm lỗi bảo mật liên quan.
Gemini 3.1 Pro	Hỗ trợ tìm hiểu GUI Scan với authentication trên ZAP.	Câu hỏi về quá trình scan authenticated bằng ZAP GUI và cấu hình trình duyệt khi scan localhost.	Hướng dẫn kiểm tra Firefox about:config để allow localhost trong quá trình cấu hình proxy/scan local.	Kiểm tra lại bằng thao tác thực tế trong môi trường local khi tìm hiểu GUI scan với authentication.
GPT-5.5	Hỗ trợ viết script tạo AI triage và testcase từ kết quả ZAP.	ZAP scan output và yêu cầu tạo AI triage report/testcase có đủ các section cần thiết.	Draft code đọc kết quả scan, tạo triage theo alert/finding, sinh testcase/checklist kiểm chứng và chuẩn hóa section trong output.	Đọc lại code, kiểm thử script, kiểm tra output có đủ section yêu cầu và xác nhận output đạt yêu cầu.
GPT-5.5	Tóm tắt nội dung được giao vào user guide.	Nội dung phần DAST/ZAP, scan workflow, AI triage và cách đọc output.	Bản tóm tắt đưa vào user guide cho các nội dung Trung Kiên phụ trách.	Đọc lại, chỉnh sửa nội dung và đối chiếu với workflow/script/report trong repository.
GPT-5.5, taste skill	Khởi tạo slide từ outline thuyết trình và user guide.	Outline thuyết trình do Trung Kiên viết, nội dung user guide và yêu cầu dùng taste skill để cải thiện giao diện.	Draft slide deck, bố cục trình bày, phân bổ nội dung seminar và cải thiện giao diện slide.	Kiểm tra lại slide, xác nhận đủ nội dung, đúng thứ tự trình bày và phù hợp với user guide/outline.
GPT-5.5	Tạo bản nháp final report.	Các nội dung đã có trong repository và yêu cầu tạo file final-report.	Bản nháp final report tổng hợp các phần liên quan.	Đọc lại và sửa thứ tự section, chỉnh path đến nội dung liên quan, bổ sung link YouTube trước khi dùng.

Xác nhận

Tôi xác nhận các nội dung AI hỗ trợ đã được tôi đọc lại, chỉnh sửa và kiểm chứng trước khi đưa vào tài liệu nhóm.

- Ngày: 23/07/2026
- Chữ ký: Lê Trung Kiên

Thành viên 2 - Mai Thị Kim Duyên

- MSSV: 23127185
- Nhóm: Group 06 - KDBK
- Đề tài: T09 - Security Testing (DAST / SAST)

Tóm tắt sử dụng AI

Công cụ	Mục đích	Đầu vào đã cung cấp	Nội dung đã sử dụng	Cách tự kiểm chứng
Gemini 3.1 Pro	Hỗ trợ viết mã Python gọi API OWASP ZAP và biên tập báo cáo OWASP Top 10.	Yêu cầu tự động hóa Spider, Active Scan, lấy alerts và chuẩn hóa nội dung báo cáo.	Bản nháp mã dùng thư viện <code>zaproxy</code> , logic gọi endpoint scan, xử lý danh sách alerts, bản nháp nội dung OWASP Top 10.	Kiểm tra lại nội dung OWASP ZAP, chạy thử script qua API, rà soát kết quả trả về.
Gemini 3.1 Pro	Hỗ trợ cấu hình authenticated scan cho ZAP trên EShop.	Yêu cầu đăng nhập lấy JWT, tạo context/user/forced-user, gắn <code>Authorization: Bearer ...</code> , dùng AJAX Spider và giới hạn local scope.	Bản nháp logic đăng nhập qua proxy ZAP, trích xuất JWT, tạo context/user, bật Forced User Mode, thêm Replacer rule, gợi ý AJAX Spider.	Đọc lại <code>zap_runtime.py</code> , sửa credential mặc định, validate chỉ scan local EShop, đối chiếu tài liệu official của ZAP về authentication, users, Replacer và AJAX Spider.

Xác nhận

Tôi xác nhận các nội dung AI hỗ trợ đã được tôi đọc lại, chỉnh sửa và kiểm chứng trước khi đưa vào tài liệu nhóm.

- Ngày: 21/07/2026
- Chữ ký: Mai Thị Kim Duyên

Thành viên 3 - Lâm Hữu Khánh

- MSSV: 23127205
- Nhóm: Group 06 - KDBK
- Đề tài: T09 - Security Testing (DAST / SAST)

Tóm tắt sử dụng AI

Công cụ	Mục đích	Đầu vào đã cung cấp	Nội dung đã sử dụng	Cách tự kiểm chứng
ChatGPT/Gemini	Hỗ trợ rà soát Semgrep SAST và finding <code>hardcoded-jwt-secret</code> .	Semgrep finding, source evidence, yêu cầu giải thích nguy cơ, PoC JWT giả mạo và remediation.	Nhận xét root cause <code>SECRET_KEY</code> hardcoded, phân tích impact, draft PoC dùng <code>jsonwebtoken</code> , checklist kiểm chứng rule ID/file/dòng code, gợi ý dùng <code>process.env.JWT_SECRET</code> .	Đối chiếu output Semgrep với evidence, kiểm tra các vị trí <code>jwt.sign</code> và <code>jwt.verify</code> , rà soát PoC, gộp duplicate findings cùng root cause.
Codex GPT-5	Hỗ trợ soạn README chạy basic scan bằng ZAP.	Yêu cầu giải thích CLI flags <code>--target, --scan-mode, --report-format, --output-file</code> và ví dụ lệnh HTML/JSON.	Dự thảo cấu trúc mục "Chạy scan", giải thích tham số CLI, ví dụ command chạy từ root project.	Đối chiếu cờ CLI với <code>scan_zap.py</code> , chỉnh đường dẫn theo repo, chạy thử basic scan local và kiểm tra file output.
Codex/ChatGPT	Hỗ trợ hoàn thiện Semgrep AI triage, Postman testcase và user guide.	Semgrep scan result JSON, <code>semgrep_triage_report.md</code> , <code>semgrep_test_cases.md</code> , lỗi cài đặt/chạy command trên Windows, yêu cầu đồng bộ tiếng Việt và tạo flow demo Semgrep.	Format lại finding Semgrep thành report có <code>Tags lỗi</code> , source evidence, <code>Postman/PoC tự động</code> , payload mẫu; cập nhật user guide cài/chạy Semgrep; tạo flow demo từ scan đến PoC; bổ sung AI audit cho các prompt hoàn thiện.	Đọc lại source/output trong <code>src/semgrep</code> , chạy <code>python -m unittest src.semgrep.test_semgrep_ai_triage</code> , kiểm tra report không ghi actual result khi chưa test, đối chiếu test case với Postman/PoC thực tế trước khi kết luận.

Xác nhận

Tôi xác nhận các nội dung AI hỗ trợ đã được tôi đọc lại, chỉnh sửa và kiểm chứng trước khi đưa vào tài liệu nhóm.

- Ngày: 23/07/2026
- Chữ ký: Lâm Hữu Khánh

Thành viên 4 - Lê Mai Hoài Bảo

- MSSV: 23127326
- Nhóm: Group 06 - KDBK
- Đề tài: T09 - Security Testing (DAST / SAST)

Tóm tắt sử dụng AI

Công cụ	Mục đích	Đầu vào đã cung cấp	Nội dung đã sử dụng	Cách tự kiểm chứng
Google Gemini 3.1 Flash	Hỗ trợ sửa script Semgrep AI triage và phân tích finding <code>hardcoded-jwt-secret</code> .	Yêu cầu chuyển từ <code>google-generativeai</code> sang <code>google-genai</code> , xử lý lỗi model/503, phân tích finding và điền template Track A.	Bản nháp mã gọi Gemini bằng <code>genai.Client</code> , retry khi API quá tải, báo cáo triage hardcoded JWT secret gồm giải thích, PoC, impact và remediation.	Cài <code>google-genai</code> , chạy lại script với <code>semgrep_results.json</code> , xác nhận xuất Markdown, đối chiếu rule ID/vị trí finding với <code>backend/server.js</code> , kiểm tra PoC JWT và remediation.
Codex/ChatGPT, OpenRouter Gemini <code>google/gemini-2.5-flash-lite</code>	Hỗ trợ hoàn thiện Semgrep AI Triage workflow.	Yêu cầu đọc tài liệu Semgrep, cấu hình OpenRouter, sửa <code>env/script</code> , giải thích lỗi <code>externally-managed-environment</code> , lỗi OpenRouter 402, xử lý toàn bộ findings, sắp xếp lại repo.	Đề xuất <code>.env.example</code> , logic đọc <code>OPENROUTER_API_KEY/OPENROUTER_BASE_URL</code> , xử lý toàn bộ <code>results</code> , pipeline <code>run_semgrep_pipeline.sh</code> , hướng dẫn chạy và unit test liên quan.	Kiểm tra cấu trúc <code>docs/semgrep</code> và <code>src/semgrep</code> , chạy cài đặt trong <code>.venv</code> , scan Semgrep, chạy triage, xác nhận 12 findings được xử lý, kiểm tra lỗi 402 là do credit/token limit, chạy unit test và kiểm tra diff.

Xác nhận

Tôi xác nhận các nội dung AI hỗ trợ đã được tôi đọc lại, chỉnh sửa và kiểm chứng trước khi đưa vào tài liệu nhóm.

- Ngày: 21/07/2026
- Chữ ký: Lê Mai Hoài Bảo

Cam kết của nhóm

Nhóm cam kết:

- Không sử dụng AI để thay thế việc hiểu công cụ, chạy kiểm thử hoặc xác minh kỹ thuật.
- Không đưa API key, `.env` thật, credential nhạy cảm hoặc scan target không được phép vào prompt.
- Không kết luận lỗ hổng chỉ dựa trên AI; mọi kết luận cần source evidence, output Semgrep/ZAP, PoC hoặc human validation.
- Ghi nhận rõ các giới hạn của AI, gồm placeholder, duplicate findings, sai taxonomy/tag OWASP, hoặc output thiếu precondition/expected result.